

SCUTTA 모바일 서비스 기술품질 검토보고서

성능 보안 사용자 경험 코드 구조 및 PWA 운영 적합성

검토일 2026년 9월 7일 | 대상 main 168e79d | 작성 Codex 기술 검토 | 수신 SCUTTA 개발 및 운영 담당자

1 종합 판단과 검토 범위

판정은 조건부 운영 적합이다. 경기 기록 서비스의 기본 구조, 권한 분리, 데이터 제약, 자동 검증은 잘 마련되어 있다. 대규모 재작성보다 초기 관리자 보안과 비동기 저장 신뢰성을 우선 수정하는 것이 효과적이다. 모바일에서는 화면이 정상적으로 보이는 것과 기록이 안전하게 저장되는 것을 별도로 평가해야 한다.

현재 자료만으로 iOS와 Android에서 문제가 없다고 보증할 수 없다. 최신 브라우저를 위한 설치·safe area·화면 높이 대응은 존재한다. 그러나 가상 키보드, OS 뒤로가기, 앱 종료, 저장 중 네트워크 전환, VoiceOver와 TalkBack, 구버전에서의 동작은 실제 기기 검증이 필요하다. Chromium의 모바일 크기 검사 통과를 iPhone 호환성 통과로 환산하지 않았다.

우선 의사결정 세 가지

- 운영 초기 관리자 비밀번호의 공개된 기본값을 제거한다. 이미 운영 중인 계정의 실제 비밀번호는 이번 검토에서 조회하지 않았다.
- 기록 저장 완료와 화면상 성공을 구분한다. 게임 점수 큐, 오래된 인증 응답, 응답 본문 제한 문제를 공통 요청 수명 관리와 회귀 테스트로 해결한다.
- 지원 OS·브라우저 범위와 온라인 전용 정책을 명시한다. PWA 설치 성공만으로 오프라인 사용·장기 로그인·백그라운드 저장을 보장하지 않는다.

평가 영역	판단	운영에 필요한 다음 근거
구조와 도메인 규칙	기반 양호	복잡한 대회 변경의 DB별 동시성 검증
보안과 운영 통제	우선 보완	초기 자격 증명 제거와 프록시 신뢰 검증
성능	정적 기반 양호 운영 지연 미측정	실제 모바일 p75와 PostgreSQL 부하 측정
모바일 사용자 경험	기본 배치 양호 저장 흐름 보완	키보드·뒤로가기·저장 중 이동·앱 복귀
PWA와 OS 호환성	구현 준비됨 실기기 판정 유보	OS별 설치·갱신·저장소·종료 시나리오
유지보수와 테스트	자동 검사 양호 통합 검증 공백	DOM 테스트와 운영 DB 통합 테스트

이전의 7점 평가는 코드 기반의 정성적 요약이었다. 본 보고서는 가중치가 검증되지 않은 정밀 점수나 미측정 Lighthouse 점수 대신, 근거 수준과 출시 전 완료 조건을 사용한다. 소스 검토, 기존 자동 검사, 격리 DB 재현, 실제 코드에서 추출한 재현, 프로덕션 빌드의 자산 측정, Chromium 화면 검사를 수행했다. 운영 계정·운영 DB·외부 사용자의 기록은 사용하지 않았다.

2 주요 위험과 근거 수준

E1은 실행 또는 산출물로 확인, E2는 코드 경로와 공식 동작에 근거한 조건부 위험, E3는 정책·측정·시험의 공백이다. E1도 표기된 환경 밖의 동작을 보장하지 않는다. P1은 우선 조치, P2는 안정성 개선, P3는 후속 개선을 뜻하며 CVSS 점수가 아니다.

ID	항목	우선도	근거	영향 범위
SEC01	고정된 최초 관리자 비밀번호	P1	E1	새 DB 배포 후 변경 전
REL01	초기화와 일반 조회의 교착	P2	E1	PostgreSQL 동시 요청
SEC02	클라이언트 점수의 무검증 수용	P2	E1	탁구공 게임 순위
REL02	응답 본문에 시간 제한 미적용	P2	E1	모든 API 호출
REL03	이전 401이 새 로그인 상태 제거	P2	E1	지연 응답과 계정 전환
UX01	화면 이동 시 점수 대기 큐 폐기	P2	E1	게임 연속 실행과 느린 통신
UX02	저장 중 후속 편집 덮어쓰기	P2	E1	관리자 정산 설정
DATA01	대진에 연결되지 않은 중복 경기	P2	E1	SQLite 동시 등록에 한정
MOB01	선택 메뉴가 가시 viewport 무시	P2	E1 E2	좌표 재현 확인 실기기 조건 미확인
SEC03	전달 IP 신뢰에 따른 제한 우회	P2	E1 E2	프록시 구성에 따라 다름
OPS01	긴 관리자 세션의 절대 만료 부재	P2	E1 E3	관리자 보안 정책
PERF01	서버 재기동과 20초 제한 충돌	P2	E2	무료 서버가 잠든 뒤 PWA 접속
PWA01	업데이트 재접근·활성화 확인 부족	P3	E2	갱신 미룸 저속 기기 다중 탭
QA01	운영 DB와 실제 UI 시험 공백	P2	E3	회귀 검출 범위

검증된 기반은 백엔드 100개 테스트, 프론트엔드 76개 테스트, Ruff 검사와 포맷, 프론트엔드 lint, TypeScript 및 프로덕션 빌드, PWA 산출물 검사 통과다. 해당 결과는 같은 커밋에서 앞선 평가 중 실행한 결과를 재사용했다. 소스 변경이 없어 의미 없는 전체 재실행은 하지 않았다.

추가 화면 검사는 Windows Chrome 152.0.7977.82의 headless Chromium에서 실제 빌드와 가상 API 자료를 사용했다. 360×800, 390×844, 768×1024, 844×390의 선수 화면 20개 조합과 390×844 관리자 화면 3개 조합에서 페이지 가로 넘침과 JavaScript 실행 오류가 없었다. 작은 자료의 정적 화면 검사이며 실제 인증·OS 키보드·PWA 설치·네트워크 지연 성능을 검증한 결과가 아니다.

미 실시 항목은 iOS 및 Android 실기기, 운영 Render 응답시간과 헤더 경로, 실제 운영 PostgreSQL 실행계획, 복구 훈련, CVE 데이터베이스 대조, 전체 접근성 적합성 평가, 장시간 게임 FPS·발열·배터리 측정이다. 미 실시 항목은 통과 또는 결함으로 단정하지 않았다.

3 보안과 운영 통제

SEC01 최초 관리자 자격 증명

backend/app/cli.py:16은 admin과 1234를 기본값으로 사용하고, Dockerfile:38은 서버 시작 전에 ensure-admin을 실행한다. 기존 테스트도 해당 계정의 로그인과 초기화 성공을 확인한다. 관리자가 존재하면 비밀번호를 바꾸지 않는 동작은 적절하지만, 새 배포에서 최초 운영자보다 먼저 접근할 수 있는 구간이 남는다.

초기 비밀번호를 배포 비밀 설정으로 필수 입력받고 공개 기본값을 제거한다. 최초 변경 전 권한 제한이나 관리자가 직접 실행하는 초기화 경로를 마련한다. 완료 기준은 비밀값 없는 운영 초기화가 실패하고, 이미 존재하는 관리자의 비밀번호는 재배포 후 유지되며, 기본값으로 로그인할 수 없는 것이다.

SEC03 전달 IP와 로그인 횟수 제한

Docker의 forwarded-allow-ips 전체 신뢰와 backend/app/api/auth.py:87의 IP 기반 제한이 결합된다. 실제 Uvicorn 미들웨어를 이용한 로컬 검증에서 동일 연결의 X-Forwarded-For 왼쪽 값만 변경해 제한 버킷을 바꿀 수 있었다. 운영 Render의 경로에서 같은 값이 보존되는지는 미확인이다. Uvicorn은 별표가 전체 신뢰를 의미한다고 설명하며, Render도 앞단 프록시가 추가한 주소와 호출자 제공 주소를 구분하도록 안내한다. [Uvicorn 설정](#), [Render 전달 헤더 주의사항](#)

운영 경로에서 신뢰할 프록시와 실제 접속 주소 추출 규칙을 먼저 정한다. 임의의 첫 번째 IP를 신뢰하거나 임의의 마지막 IP를 사용자 주소로 바꾸는 단순 수정은 피한다. 완료 기준은 위조 단일·복수 전달 헤더로 같은 사용자의 제한 버킷을 바꾸지 못하고, 서로 다른 정상 사용자는 구분되는 것이다.

OPS01 관리자 장기 세션

backend/app/core/config.py:38과 backend/app/api/deps.py:123은 400일 TTL을 7일 이상 지난 활동에서 다시 연장한다. 같은 토큰을 유지하고 생성 시점 기준 절대 만료나 관리자·선수 구분이 없다. 800일 전에 만들어졌지만 아직 만료되지 않은 테스트 관리자 세션도 정상 인증된 뒤 400일 연장됐다. 이는 세션 탈취 증거가 아닌, 절대 만료가 없다는 동작 확인이다.

선수의 로그인 편의와 관리자 권한 수명을 별도로 설계한다. 예를 들어 관리자 절대 만료와 민감 작업의 최근 재인증을 정책으로 정하되, 구체 기간은 운영 방식에 맞춰 결정한다. 완료 기준은 절대 기간을 넘긴 세션이 활동 여부와 관계없이 거절되고, 비밀번호 변경·초기화가 기존 세션을 확실히 폐기하는 것이다. [OWASP 세션 관리](#)

이미 있는 방어와 보강 범위

비밀번호 해싱, 해시된 무작위 세션 토큰 저장, HttpOnly·Secure·SameSite 쿠키, 역할별 API 검사, 출처 검사, CSP·HSTS, non-root 컨테이너, 비밀 파일 제외는 장점이다. 인증 토큰을 localStorage에 저장하지 않는다. 누락 Origin 정책은 문서화할 필요가 있지만, 현재 CSRF 공격을 재현하지 않았으므로 확정 취약점으로 표기하지 않는다. 무작위 DB 세션 구조에 JWT용 SECRET_KEY가 없다는 사실도 결함이 아니다. [OWASP CSRF](#)

4 데이터와 비동기 요청의 신뢰성

REL01 PostgreSQL 초기화 교착

backend/app/api/admin.py:370은 대회 테이블들을 먼저 독점 잠금 뒤 사용자 테이블을 잠근다. 일반 요청은 인증 조회에서 사용자 테이블의 읽기 잠금을 유지한 채 대회 조회로 진입한다. 격리 PostgreSQL 17에서 실제 인증·초기화 코드로 이 순환 대기를 재현했고 DeadlockDetected로 초기화가 실패했다. 임시 서버는 종료했으며 기존 DB는 사용하지 않았다. 인증까지 포함한 트랜잭션 경계와 잠금 순서를 통일하고, 조회·결과 제출·비밀번호 변경·동시 초기화가 함께 실행되는 회귀 검사를 추가한다.

DATA01 SQLite의 연결되지 않은 경기

backend/app/services/competitions.py:1251의 대진 조회와 신규 경기 연결은 PostgreSQL 행 잠금에 의존한다. 파일 기반 SQLite에서 빈 대진을 두 요청이 읽고 서로 다른 날짜의 결과를 쓰도록 했을 때, 경기 2개와 대진 링크 1개가 남았다. 연결되지 않은 경기도 전체 통계에 집계된다. 로컬 SQLite의 조건부 결함으로 한정하며, 운영 PostgreSQL에서 같은 현상을 확인했다는 의미가 아니다. SQLite 쓰기를 직렬화하거나 조건부 연결 갱신 실패 시 경기 생성까지 롤백해야 한다.

SEC02 게임 점수의 신뢰 경계

backend/app/api/minigames.py:148은 탁구공 점수의 범위만 확인한다. 신규 선수의 첫 요청에 100만 점을 넣자 게임 없이 저장됐다. 순위의 공정성이 필요하다면 서버가 발급한 게임 실행 상태와 검증 가능한 진행 기록이 필요하다. 실행 ID나 플레이 시간 검사만으로 완전한 부정 방지가 되는 것은 아니다. 친목용 자기신고 기록으로 허용할 경우 그 한계를 명시하고 상품·정산 근거로 사용하지 않는 정책을 정한다. 동전 게임은 서버 난수와 원자 갱신을 사용하므로 동일하게 취급하지 않는다.

REL02 응답 본문 수신의 시간 제한

frontend/src/api/client.ts:58은 헤더를 받자마자 타이머와 호출자 취소 연결을 해제한다. 이후 JSON 본문이 끝나지 않는 스트림에서는 요청이 계속 대기하고 호출자 취소도 전달되지 않았다. 본문 읽기까지 같은 deadline과 finally 범위에 포함하고, fetch 실패·본문 실패·취소·시간 초과를 구분한다. 부분 JSON을 보낸 뒤 멈추는 성공 및 오류 응답 모두 제한 시간 내 종료되어야 한다.

REL03 이전 로그인 요청의 늦은 인증 실패

frontend/src/auth/AuthContext.tsx:62은 전역 인증 만료 이벤트에 무조건 사용자 상태를 지운다. 기존 요청 보류, 새 계정 로그인, 기존 요청 401 순서에서 새 로그인 화면 상태가 제거되는 것을 재현했다. 요청 시작 시 인증 세대를 기록하고 현재 세대와 일치할 때만 실패를 적용한다. 같은 원칙을 재조회·로그아웃·앱 복귀에도 적용한다.

위 문제의 해결은 자동 재시도만 추가하는 작업이 아니다. 쓰기 요청의 응답이 유실되면 서버 반영 여부가 모호하다. 읽기는 제한된 재시도, 쓰기는 멍등 키 또는 결과 조회와 사용자에게 보이는 확인 상태가 필요하다. 경기의 일일 중복 제약은 유용하지만 모든 쓰기의 멍등성을 대신하지 않는다.

5 모바일 성능과 전송 비용

현재 산출물은 과도하게 큰 SPA라고 단정할 수준은 아니다. 주 진입 JavaScript와 CSS의 압축 합계는 약 94KB다. 실제 모바일 지연은 서버 재기동, 통신 왕복, 기기 CPU, 설치·캐시 상태의 영향을 함께 받는다. 로컬 파일 크기를 LCP 또는 INP 측정값으로 제시하지 않는다.

프로덕션 산출물	원본 바이트	gzip 바이트	해석
주 진입 JavaScript	247257	79119	React 및 공통 실행 코드 포함
공통 CSS	73011	14799	모든 화면의 스타일 포함
동전 마스크 PNG	418678	401113	작은 마스크에 비해 큰 원본
전체 dist 파일 합계	990971	미집계	최초 화면 전송량과 다름
SW precache	약 468439	미집계	빌드 로그 37개 457.46KiB

gzip 수치는 같은 빌드 파일을 Python gzip 압축 수준 5로 압축해 계산했다. HTTP 헤더·캐시·전송 협상은 포함하지 않는다. dist 합계와 precache 크기, 실제 최초 탐색 전송량은 서로 다른 지표다.

PERF01 무료 서버의 기동과 요청 제한

render.yaml:5은 무료 웹 서버이고 API 제한은 20초다. Render 공식 문서는 유휴 15분 후 정지 및 재기동 약 1분을 설명한다. 설치된 PWA는 캐시된 화면부터 열 수 있어 서버가 깨어나기 전에 인증 조치가 실패할 수 있다. 코드와 서비스 정책에 근거한 위험이며 실제 운영 cold start는 측정하지 않았다. [Render 무료 서비스](#)

모바일 운영 목표가 즉시 사용 가능이라면 잠들지 않는 서버 구성이 가장 직접적인 대안이다. 무료 구성을 유지한다면 서버 연결 중 상태, 읽기 요청에 한정된 제한된 재시도, 수동 복구를 설계한다. 모든 요청 시간을 무조건 늘리거나 쓰기를 자동 반복하는 방식은 피한다. 15분 이상 유휴 뒤 설치 앱을 실행해 정상 진입 또는 이해 가능한 복구 화면이 나오는 것이 완료 조건이다.

작은 이미지의 불필요한 전송 비용

frontend/src/styles.css:1711은 최대 88 CSS px 수준의 동전 마스크에 1254×1254 RGBA PNG를 사용한다. 파일 하나가 dist 전체의 약 42%이며, 단순 RGBA 픽셀 버퍼만 약 6.29MB다. 후자는 실제 프로세스 메모리 측정값이 아니다. 작은 알파 마스크 또는 원본 벡터로 대체하고 2배·3배 화면에서 형태를 비교한다. 현재 파일은 SW precache에 포함되지 않는다. 이 파일이 홈 화면 최초 접속 때 반드시 다운로드된다는 뜻도 아니다.

미리 읽기와 렌더링 비용

frontend/src/App.tsx:111은 로그인 1초 뒤 해당 역할의 여러 화면을 일괄 import한다. SW도 화면 자산을 사전 저장하므로, 요청·캐시 상태에 따라 초기 통신과 CPU 작업이 겹칠 수 있다. 이후 이동을 빠르게 하는 장점이 있어 제거보다 idle 시점·가능한 경우 데이터 절약·자주 쓰는 화면 우선 정책을 비교한다. Canvas DPR 2 제한과 화면 복귀 시 시간차 초기화는 긍정적이다. 매 프레임의 gradient-blur·기하 계산은 저사양 기기의 FPS·발열 측정 후 최적화한다.

6 백엔드 성능과 확장 기준

현재 규모를 확인하지 않은 상태에서 Redis, 별도 통계 테이블, 비동기 DB 또는 마이크로서비스 도입을 권고할 근거는 없다. 아래 개인 통계·관리자 목록은 빈 SQLite 스키마에서 실제 서비스 SQL의 EXPLAIN QUERY PLAN을 확인했다. 대회 목록 쿼리 수는 별도로 시험 대회를 생성해 측정했다. PostgreSQL 실행계획이나 운영 응답시간은 아니다.

검증 대상	관찰 결과	판단
개인 1명 통계 조회	matches 스캔 2회와 참가자 집합 materialize	개인 조건을 UNION 내부로 전달할 후보
관리자 일반 경기 LIMIT 20 조회	COUNT 전체 스캔 목록 전체 스캔과 임시 정렬	누적 데이터에서 인덱스 검토
개인 리그 목록 1개	서비스 SQL 3회	인증 조회 제외
개인 리그 목록 100개	서비스 SQL 3회	목록의 전형적 N+1 없음
개인 리그 100개와 단체전 1개	서비스 SQL 4회	쿼리 수는 양호 행 수는 증가

backend/app/services/stats.py:101의 개인 통계는 전체 참가자 집계를 만든 뒤 사용자 조건을 적용한다. 개인 조회에 한해 양쪽 UNION 분기에 사용자 조건을 넣는 작은 개선부터 검토한다. 전체 랭킹·정산이 전체 경기를 집계하는 것은 기능상 자연스럽다.

backend/app/services/matches.py:284의 일반 경기 필터와 날짜·시각·ID 정렬에 맞는 인덱스는 없다. 실제 PostgreSQL의 대표 자료에서 EXPLAIN ANALYZE와 버퍼 사용을 확인한 뒤 부분 인덱스를 검토한다. COUNT·깊은 OFFSET 비용이 목표를 넘는 경우 커서 방식이나 정확한 전체 개수의 필요성을 재검토한다.

단체전은 팀 수 상한이 없고 T팀에서 T(T-1)/2개 대결을 만든다. 20팀은 190대결, 50팀은 1225대결이다. 이는 공식에서 계산한 예시이며 실제 사용량이 아니다. 팀 상한과 오래된 대회 목록 분할은 작은 변경으로 모바일 응답과 화면 크기를 제한할 수 있다. 완료 여부 하나를 확인하려고 전체 상세 DTO와 순위를 만드는 backend/app/services/competitions.py:1176도 전용 진행률 조회로 단순화할 후보다.

연결과 동시성 예산

현재 설치된 SQLAlchemy의 PostgreSQL 엔진 기본값을 연결 없이 확인했을 때 풀 5개, 추가 연결 10개, 대기 30초였다. AnyIO 기본 스레드 한도는 40개다. 운영에서 동일한 자원이 보장된다는 뜻은 아니지만, DB 연결 대기가 API의 20초 제한을 넘을 수 있는 구성이다. worker를 늘리면 DB 연결과 프로세스별 로그인 제한도 함께 바뀐다. 먼저 풀 대기, SQL 시간, 잠금 대기, 5xx를 관측한다.

제안하는 성능 합격 기준은 측정 결과가 아니다.

- 실제 규모가 없을 때 시험 초안은 선수 200명, 경기 2만 건, 단체전 최대 20팀, 동시 사용자 10명으로 잡고 운영자 확인 후 조정한다.
- 운영과 같은 PostgreSQL에서 warm 주요 읽기 API p95 500ms 이하, 풀 timeout·교착·5xx 0건을 목표 초안으로 삼는다. 저장은 정확성과 중복 방지가 우선이다.
- 모바일 실제 방문 p75에서 LCP 2.5초 이하, INP 200ms 이하, CLS 0.1 이하를 목표로 한다. 공개 지표 자료가 부족하면 익명 집계 방식의 자체 측정을 고려한다. [Google Core Web Vitals](#)
- 게임은 목표 기기에서 2분 이상 실행하고 프레임 시간, 긴 작업, 발열을 기록한다. 아직 FPS 수치나 배터리 합격 판정은 없다.

7 모바일 사용자 경험과 접근성

기본 화면은 제출 버튼, 검색, 하단 5개 메뉴, 역할별 관리 화면으로 비교적 단순하다. 입력 16px, 모바일 주요 아이콘 44×44px, safe area 여백과 작은 높이의 별도 스타일이 있다. 검사한 23개 화면 조합에서 페이지 가로 넘침은 없었다. 다만 목록 데이터가 작고, 키보드와 확대·긴 이름·오류 모달을 모두 검사한 것은 아니다.

UX01 화면을 떠날 때 점수 저장이 사라짐

frontend/src/components/PaddleFlightGame.tsx:396은 앞선 저장을 기다리는 큐가 실행될 때 컴포넌트가 사라졌으면 항목을 지운다. 0점 저장을 보류하고 다음 1점을 큐에 넣은 뒤 같은 계정에서 화면을 떠나면, 완료 점수는 0과 1인데 서버에 보낸 점수는 0뿐이었다. 큐를 게임 컴포넌트보다 오래 유지하고 서버 확인 전에는 저장 중·재시도 상태를 보여야 한다. 장기 보존을 추가할 경우 사용자와 게임·리셋 세대를 함께 기록해 다른 계정이나 초기화 이전 점수를 잘못 재전송하지 않도록 한다.

MOB01 키보드와 선택 목록

frontend/src/components/CustomSelect.tsx:141은 visualViewport 이벤트는 듣지만 위치 계산에는 innerHeight만 사용한다. layout 높이 800, 실제 보이는 높이 400, 버튼 아래쪽 390인 조건에서 목록 아래쪽이 684로 계산됐다. 좌표 문제는 재현됐지만 실제 기기의 해당 입력 순서는 미검증이다. Chrome Android의 키보드는 기본적으로 visual viewport만 줄일 수 있으며 iOS도 이런 좌표 차이를 고려해야 한다. dvh만으로 키보드 대응을 보장하지 않는다. [Chrome viewport 설명](#)

선택 목록과 모달 높이 설정 (frontend/src/styles.css:4498)을 가시 영역 기준으로 검토한다. 이름 입력 직후 성별 선택, 날짜 입력 후 점수 선택, 키보드 닫힘 애니메이션, 화면 200% 확대 상태에서 마지막 항목과 저장 버튼에 접근 가능해야 한다.

UX02 정산 설정의 후속 편집 손실

frontend/src/pages/AdminSettlementsPage.tsx:62은 저장 응답으로 전체 폼 상태를 교체한다. 저장 중 입력이 가능하여 A 제출 후 B로 바꾸면 응답 도착 시 A로 돌아간다. 저장 중 필드를 잠그거나 제출 후 변경 세대를 보존한다. 느린 모바일 통신일수록 노출 시간이 길어진다.

종료와 복귀

활성 동전 게임은 frontend/src/pages/MinigamePage.tsx:501에서 종료 상태에만 나가기 버튼을 제공한다. standalone에서는 브라우저 UI가 없어 지속 통신 오류 시 탈출이 더 어렵다. 항상 보이는 종료 경로를 제공하고 전송 중 처리만 명확히 한다. 모달·게임 상태는 history와 연결되어 있지 않아 Android Back의 첫 동작이 오버레이 닫기라는 보장은 없다. OS별 시험 후 탐색 정책을 통일한다.

접근성 판정의 범위

공통 모달은 초점 복원·Tab 순환을 제공한다. 반면 모달 안 CustomSelect 목록이 document.body로 portal되어 aria-modal 밖에 놓인다. VoiceOver·TalkBack의 실제 탐색을 확인하고 가능하면 모달 내부 portal host를 사용한다.

WAI ARIA 모달 패턴

측정에서 홈의 전체 링크는 약 45×17px, 대회 뒤로가기 링크는 62×18px였다. 터치 여유를 늘릴 후보지만, 간격·인라인 예외를 검토하지 않았으므로 WCAG 위반으로 단정하지 않는다. 44px는 편의 목표이고 WCAG 2.2 AA의 최소 기준은 예외를 포함한 24px다. 색 대비·읽기 순서·큰 글씨를 포함한 전체 접근성 합격 판정은 아직 없다. [W3C 대상 크기 기준](#)

8 PWA와 OS별 지원 판정

지원 범위를 OS 이름만으로 정하면 불충분하다. 같은 iPhone도 Safari 탭, 홈 화면 앱, 제3자 브라우저, 카카오톡 안의 화면은 설치와 저장소·탐색 경험이 다를 수 있다. Android도 OS 버전 외에 Chrome-WebView-Samsung Internet 버전을 함께 기록해야 한다.

Vite 설정에는 별도 build.target이나 legacy 플러그인이 없다. 설치된 Vite 코드와 공식 문서의 기본 대상은 Chrome 111 이상, Edge 111 이상, Firefox 114 이상, Safari 16.4 이상이다. 이는 번들 구문 대상이며 앱의 모든 API·CSS 동작 보증이 아니다. 구형 iOS까지 지원한다고 선언하려면 필요한 API의 feature detection·대체 구현과 별도 시험이 필요하다.

Vite 브라우저 호환성

환경	코드상 준비	현재 판정	우선 확인할 항목
iPhone Safari 16.4 이상	수동 설치 안내와 safe area	실기기 미검증	키보드 모달 큰 글씨 세션
iPhone 홈 화면 앱	standalone 아이콘 SW	실기기 미검증	설치 전후 인증 종료 복귀 갱신
iOS 26 계열	웹 앱으로 열기 안내 포함	공식 동작과 대체로 정합	더보기 공유 메뉴와 토글
Android Chrome 111 이상	설치 이벤트 및 수동 안내	실기기 미검증	키보드 Back 설치 후 재실행
Android 설치 앱	manifest scope start URL	실기기 미검증	프로세스 종료 저장 갱신
Samsung Internet	Android 일반 안내로 분류	안내 정확성 미확인	실제 설치 메뉴와 입력 동작
카카오톡 iOS 및 Android	외부 브라우저 안내 분리	실제 앱 버전 미검증	열기 경로 로그인 연속성
오래된 Safari와 WebView	별도 하위 호환 설정 없음	지원 보증 범위 밖	필요 사용자 비중부터 확인

iOS는 Android 방식의 설치 프롬프트가 없더라도 공유 메뉴 기반 안내로 설치할 수 있다. WebKit은 iOS 16.4부터 제3자 브라우저의 홈 화면 추가 지원도 설명한다. 따라서 iOS Chrome에서 설치가 불가능하다고 일괄 판단하면 부정확하다. 현재 Apple 안내의 Safari 메뉴는 레이아웃에 따라 더보기에서 공유로 이동하며 웹 앱으로 열기 토글을 사용할 수 있다. WebKit iOS 웹 앱, Apple 설치 안내

PWA 구성의 장점

manifest의 id-scope-start_url은 모두 루트로 일치하고 standalone, 192-512 아이콘과 maskable 아이콘, Apple touch icon이 빌드에 포함된다. viewport-fit과 inset 여백, 사용자 선택 갱신, 전면 복귀 및 온라인 복구 때 SW 확인도 구현되어 있다. 같은 출처의 화면과 API, HttpOnly 쿠키는 별도 출처 쿠키보다 구성을 단순하게 만든다.

과도한 보장은 피해야 한다. manifest의 portrait-primary가 모든 환경에서 회전을 고정하지는 않는다. 400일 서버 세션은 OS가 쿠키를 400일 보관한다는 보장이 아니다. 반대로 Safari가 이 앱을 반드시 7일마다 로그아웃시킨다는 주장도 근거가 없다. WebKit은 홈 화면 웹 앱의 첫 출처를 7일 script-writable 저장소 정리에서 제외한다고 설명한다. 사용자의 저장소 삭제와 OS 정책까지 보장하는 것은 아니다. WebKit 추적 방지

9 PWA 오프라인 갱신과 앱 생명주기

온라인 전용 범위를 명시한다. 현재 SW는 화면 자산을 사전 저장하며 API 응답 캐시나 오프라인 경기 제출 큐는 없다. API-health 경로는 SPA fallback에서 제외한다. 새 실행 시 인증 조회가 필요하므로 오프라인으로 실행하면 연결 오류 화면에 도달할 수 있다. 친목 기록 서비스가 온라인 전용인 것은 합리적인 선택이며 그 자체가 PWA 결함은 아니다. 앱 설치 안내가 오프라인 기록 보존을 암시하지 않도록 해야 한다.

오프라인 쓰기를 도입할 때에는 단순 fetch 재시도보다 사용자별 대기함, 중복 방지, 서버 처리 결과 확인, 로그아웃 시 격리, 초기화 세대 처리, 오래된 자료 표시가 필요하다. 개인 API 전체를 CacheFirst로 바꾸면 계정 전환·데이터 최신성 문제가 생길 수 있다. 먼저 현재 게임의 저장 큐 손실과 연결 복구를 해결한다.

PWA01 업데이트 재접근과 활성화 확인

frontend/src/components/PwaManager.tsx:186에서 알림을 닫으면 같은 세션에 다시 여는 설정 메뉴가 없다. 동일한 waiting worker가 계속 있을 때 갱신 확인이 알림을 다시 띄운다는 보장도 없다. 설정에 현재 버전과 업데이트 준비 상태를 남기고 사용자가 다시 적용할 수 있게 한다.

frontend/src/components/pwaUpdate.ts:57은 3초 후 활성화 확인 없이 새로고침하는 fallback이 있다. 무한 대기를 피하려는 의도는 이해되지만 느린 activation이나 다중 탭에서 새 버전 적용 여부가 모호해질 수 있다. 새 controller 또는 activated 상태 확인 후 새로고침하고, 제한 시간 초과는 재시도 가능한 상태로 처리하는 방향을 검토한다. SW의 install-waiting-activate 단계는 구분해야 한다. [PWA 업데이트 생명주기](#)

운영 배포는 새 UI와 이전 API, 이전 UI와 새 API가 잠시 공존한다고 가정한다. 현재 사용자 선택 갱신은 입력을 보호하는 장점이 있지만 구형 클라이언트가 남을 수 있다. API 계약을 한 버전 이상 호환하고, 즉시 제거가 필요한 변경은 별도 안내와 복구 경로를 준비한다. 같은 origin에서 /api와 정적 화면을 함께 서비스하는 구조는 유지해도 된다.

백그라운드 전환과 종료

Canvas는 전면 복귀 때 프레임 시간차를 초기화한다. 그러나 복귀 직후 자동 재개보다 탭해서 계속하는 방식이 손실과 당황을 줄일지 실기기로 확인할 필요가 있다. OS가 앱을 종료하면 React state와 메모리 큐가 사라진다. hidden 이벤트 이후 추가 JavaScript 실행이나 unload 이벤트를 보장할 수 없으므로 종료 직전에만 저장하는 설계는 충분하지 않다.

[Chrome 페이지 생명주기](#)

완료 판정 시나리오

- 새 버전 배포 후 입력 중 강제 새로고침이 없고, 저장 뒤 사용자가 갱신을 적용할 수 있다.
- 알림을 닫고 다시 찾을 수 있으며, 설치 앱과 브라우저 탭을 함께 열어도 버전 전환이 복구 가능하다.
- 앱 종료 전 저장 중·완료·실패 상태가 구분되고, 재실행 후 미확정 결과를 중복 없이 확인할 수 있다.
- 비행기 모드, Wi-Fi에서 이동통신 전환, 서버 기동, 저장 응답만 유실되는 경우를 각각 검사한다.

10 코드 구조와 정리할 요소

현재 FastAPI-SQLAlchemy-React 조합과 단일 배포 구조는 서비스 규모에 적합하다. API·서비스·스키마 분리, 순수 함수 테스트, 라우트 지연 로딩은 유지할 가치가 있다. 파일 수를 늘리는 것이 목적이 되어서는 안 된다.

대상	관찰	권고
대회 서비스 1716줄	규칙 조회 DTO 변경 트랜잭션 혼합	순위 계산과 진행률 조회부터 분리
대회 상세 페이지 1137줄	화면과 여러 저장 복구 흐름 공존	폼과 요청 상태 단위로 책임 분리
탁구공 게임 913줄	그리기 게임 상태 저장 큐 혼합	렌더러와 저장 수명을 별도 관리
공통 CSS 5099줄	페이지 스타일과 모바일 보정 집중	기능별 영향 범위와 토큰 정리
공통 API 클라이언트	요청 경계와 인증 이벤트 혼합	본문까지 수명 관리 인증 세대 일관화

정리 근거가 있는 항목

- 정산의 opponents 상품 설정은 기능 잔재다. 정산 화면과 실제 부문은 경기·승리·패배 세 가지인데, backend/app/schemas/settlements.py:17과 저장 모델은 상대 수 상품을 계속 지원한다. 정산 설정에서만 폐기 정책을 정하고 API 호환성과 DB 마이그레이션을 거쳐 정리한다. 정상 사용 중인 상대 수 랭킹은 유지한다.
- 허용 점수 조합은 backend/app/schemas/matches.py:9와 backend/app/services/matches.py:16에 중복 정의되어 있다. Python 규칙 상수를 공유하되 DB CHECK와 API 검증이라는 방어 계층은 유지한다.
- 단일 부문 랭킹도 네 부문 전체를 계산한다. 현재 프론트가 전체 랭킹을 사용하므로 우선도가 낮다. 사용되지 않는 API라고 즉시 삭제하기보다 외부 소비자와 과거 호환성을 확인한다.
- 전 화면 선로딩, 큰 마스크트 원본, 전체 상세를 만드는 완료 확인은 기능을 유지하면서 비용을 줄일 수 있는 후보다.

바로 삭제하면 안 되는 항목

- MatchKind.DAILY는 새 생성 경로에서 쓰지 않더라도 과거 DB와 응답 호환값일 수 있다. 저장된 실제 값과 이전 클라이언트 사용을 확인한 뒤 폐기한다.
- httpx2는 설치된 Starlette TestClient가 사용한다. pyyaml은 배포 테스트, tzdata는 Windows 시간대, pycopg는 운영 DB에 필요하다. 직접 import 검색만으로 불필요한 패키지라고 판단하지 않는다.
- PWA 라이브러리와 커스텀 갱신 처리가 함께 있다는 이유만으로 한쪽을 제거하지 않는다. 현재 제어 역할과 회귀 검증을 먼저 확인한다.
- 전역 CSS에서 특정 화면에 안 쓰이는 규칙은 다른 페이지·미디어 조건에 쓰일 수 있다. 한 화면의 coverage만으로 일괄 삭제하지 않는다.

배포 재현성은 삭제보다 우선한다. 프론트는 lockfile과 frozen 설치가 있다. 백엔드는 범위 의존성과 pip install만 사용하므로 같은 커밋의 빌드 결과가 시점에 따라 달라질 수 있다. 잠금 파일 또는 버전·해시가 고정된 설치 목록을 CI와 Docker에 함께 적용한다. 특정 패키지의 현존 취약점을 확인했다는 뜻은 아니다. [pip 재현 가능한 설치](#)

11 운영 관측과 출시 검증

Uvicorn의 기본 접근·오류 로그는 존재한다. 그러나 관리자 변경의 행위자·대상·전후 상태·요청 ID를 남기는 감사 이벤트와 애플리케이션 수준의 오류·지연 집계는 부족하다. 초기화, 선수 삭제, 비밀번호 초기화, 경기 정정은 기록 분쟁과 복구에 필요한 최소 이력을 남긴다. 원문 비밀번호와 세션 토큰은 로그에 남기지 않는다. [OWASP 로그 지침](#)

DB는 유료 Render PostgreSQL로 설정되어 있다. 따라서 백업이 전혀 없다는 평가는 부정확하다. Render는 유료 DB의 시점 복구를 제공하지만 실제 계정의 복구 창, 장기 보존, 복구 소요시간과 운영 전환 절차는 별도로 확인해야 한다. 별도 DB로 복구하여 선수·경기·대회 관계를 점검하는 훈련이 필요하다. RPO는 허용 데이터 손실 시간, RTO는 허용 복구 시간이며 운영자가 목표를 정해야 한다. [Render 백업과 복구](#)

공통 API 테스트는 backend/tests/conftest.py:52에서 SQLite로 고정된다. CI에 PostgreSQL이 있어도 대부분의 API 동시성을 검사하지 않는다. 프론트엔드도 Node 환경의 함수·API 유틸 중심이다. 테스트 개수보다 아래 위험을 직접 검출하는 검사가 필요하다.

시험	수행 환경	합격 기준
초기 비밀번호와 권한	새 운영 설정의 격리 DB	기본값 로그인 불가와 기존 관리자 보존
초기화 대회 조회 동시 실행	PostgreSQL 독립 연결	교착과 5xx 없이 일관된 완료
부분 응답 멈춤과 취소	API 클라이언트 단위 시험	본문도 deadline 내 종료
계정 전환 후 이전 401	DOM 통합 시험	새 사용자 상태 유지
연속 게임 후 메뉴 이동	DOM와 느린 응답	미전송 기록의 묵시적 폐기 없음
저장 중 후속 편집	DOM 통합 시험	편집 보존 또는 명시적 입력 잠금
키보드와 선택 메뉴	iPhone Android 실제 기기	모든 옵션과 저장 버튼 접근 가능
모달 읽기 순서	VoiceOver TalkBack	옵션 탐색 선택 초점 복귀 성공
앱 전환 종료 재실행	설치 앱 실제 기기	기록 상태 복구와 계정 분리
설치 전후 로그인	Safari Chrome 설치 앱	인증 전환과 재로그인 안내 명확
새 SW와 다중 탭	실제 설치 앱과 브라우저	입력 손실 없이 갱신 및 재시도
네트워크 전환과 응답 유실	실제 기기와 통제된 프록시	중복 저장 없이 결과 확인
긴 이름 큰 글씨 회전	360px와 landscape 실제 기기	핵심 정보 조작 접근 가능
백업 복원	운영과 분리된 PostgreSQL	관계 일관성과 전환 절차 확인

최소 시험 조합은 iPhone Safari와 홈 화면 앱, Android Chrome과 설치 앱, Samsung Internet, 주요 유입 경로인 카카오톡이다. 현재 안정 버전과 실제 사용자 중 가장 오래된 지원 버전을 기록한다. iOS의 버전 숫자만으로 전체 사용자를 대표하지 않는다. 모든 테스트에 OS·브라우저·앱 버전, 빌드 해시, 설치 여부, 통신 조건을 남긴다.

12 실행 순서와 완료 조건

첫 단계는 신뢰성과 보안이다. 초기 관리자 기본값 제거, 인증 세대 처리, 본문 timeout, 게임 저장 큐 손실, PostgreSQL 초기화 교착을 수정한다. 각 수정과 함께 기존 코드에서 실패하고 수정 후 통과하는 좁은 회귀 검사를 추가한다. 점수 순위의 신뢰 수준과 관리자 세션 정책도 운영자가 결정한다.

두 번째 단계는 모바일 출시 검증이다. 지원 브라우저 범위를 문서화하고 실제 기기에서 키보드·Back·화면읽기·저장 중 이동·앱 종료·PWA 갱신을 검사한다. 연결 지연·저장 중 실패·완료를 사용자가 구별하도록 한다. 무료 서버를 유지할지 결정하고 cold start에 맞는 읽기 복구 흐름을 검증한다.

세 번째 단계는 측정에 따른 비용 절감이다. 마스코트 자산 축소와 미리 읽기 정책 비교를 먼저 수행한다. 운영 지연·풀 대기·느린 SQL을 측정한 뒤 개인 통계 조건 전달, 경기 목록 인덱스, 대회 규모 제한을 적용한다. 측정 목표를 충족하면 캐시·비동기 재작성·별도 통계 저장소는 도입하지 않아도 된다.

작업 묶음	담당 역할	완료를 보여 주는 결과
초기 관리자와 프록시 정책	백엔드 운영	새 배포·위조 헤더 시험 결과
요청과 인증 수명 관리	프론트엔드	부분 본문·이전 401 회귀 검사
저장 상태와 점수 큐	프론트엔드 백엔드	이동·종료·계정 변경 시 결과 일관성
초기화 잠금	백엔드	운영 DB와 같은 PostgreSQL 동시 시험
모바일 입력 접근성	프론트엔드 QA	OS별 실기기 사례와 합격 기록
PWA 업데이트 복구	프론트엔드 QA	미룸 재접근 다중 탭 갱신 시험
전송과 조회 비용	프론트엔드 백엔드	자산 크기 및 동일 조건 전후 측정
복구와 감사 기록	운영 백엔드	실제 복원 훈련과 사건 추적 사례

담당 역할은 제안이며 실제 팀 배치이나 일정 약속이 아니다. 기능 변경 범위와 운영 규모가 확정되지 않아 임의의 날짜·공수를 정밀 추정하지 않았다.

출시 판정 기준

P1이 해결되고, 데이터 손실·인증 상태 오류·운영 DB 교착에 대한 회귀 검사가 통과하며, 선언한 최소 OS의 실제 기기에서 핵심 기록 흐름이 통과해야 한다. 미해결 P2는 운영자가 발생 조건과 대응을 이해하고 수용 여부를 기록한다. PWA 설치·빌드 성공이나 정적 화면 검사만으로 출시 승인하지 않는다.

재검토할 때 보존할 자료

커밋, lockfile, 빌드 자산 크기, 자동 검사 로그, 재현 절차, OS별 시험표, PostgreSQL 쿼리 계획과 부하 조건, 복구 훈련 결과를 같은 릴리스 단위로 보존한다. 개인 계정·비밀번호·원문 세션·실제 사용자 이름을 시험 보고서에 포함하지 않는다. 이번 브라우저 검사는 가상 선수 자료를 사용했다.

부록 검증 기록과 참고 자료

검사 명령은 저장소의 기존 환경을 사용했다. 백엔드는 ruff check, ruff format --check, pytest 100개 통과, 프론트엔드는 pnpm lint, pnpm test 76개 통과, pnpm build, pnpm verify:build 통과다. 마이그레이션 왕복 검사는 pytest에 포함된다. 별도 Docker 이미지 재빌드와 실제 운영 DB의 alembic 검사를 이번에 수행했다고 주장하지 않는다.

추가 검증은 격리 PostgreSQL 17의 초기화 교착, 파일 SQLite 독립 연결의 대진 경쟁, 메모리 DB의 임의 게임 점수와 장기 세션, Uvicorn 전달 헤더 미들웨어, 실제 프론트 코드에서 추출한 비동기 상태·좌표 재현, 빌드 파일 분석, Chromium 23개 화면 조합이다. 함수 재현은 실제 OS 이벤트를 대체하지 않으며, SQLite 계획은 PostgreSQL 계획을 대체하지 않는다.

아래 문서는 2026년 9월 7일 검토에서 대조한 1차 자료다. 오래된 문서의 플랫폼 설명은 해당 기능 범위에 한해 사용했다. 공급자의 정책과 브라우저 지원 범위는 이후 변경될 수 있으므로 릴리스 검증 때 다시 확인한다.

제공자와 문서	보고서에서 사용한 범위
Google Web Vitals	모바일 p75의 LCP INP CLS 목표와 측정 구분
Vite Production Build	기본 브라우저 대상과 구문 변환 범위
Chrome Viewport Behavior	키보드 visual viewport와 layout viewport 차이
Chrome Page Lifecycle	모바일 hidden 종료 시 실행 보장 제한
PWA Update	SW 설치 대기 활성화 갱신
WebKit iOS Web Apps	iOS 홈 화면 앱과 제3자 설치 경로
Apple 웹 앱 안내	공유 메뉴와 웹 앱으로 열기
WebKit Tracking Prevention	홈 화면 첫 출처와 저장소 정책
W3C Target Size	터치 대상 최소 크기와 예외
WAI ARIA Dialog	모달의 조작 요소와 접근성 구조
OWASP Session Management	절대 만료와 세션 통제
OWASP CSRF	출처 검증의 방어 범위
OWASP Logging	감사 이벤트와 비밀값 제외
Uvicorn Settings	전달 헤더와 프록시 신뢰
Render XFF 안내	전달 IP의 호출자 입력 구분
Render Free	무료 웹 서버 유희 정지와 재기동
Render PostgreSQL Backups	유료 DB 시점 복구와 운영 확인
pip Repeatable Installs	동일 의존성 재현과 고정 설치

애플리케이션 소스는 변경하지 않았다. 보고서의 코드 링크는 검토 시점의 로컬 저장소 절대 경로와 행 번호이며, 다른 컴퓨터에서는 같은 커밋의 대응 파일을 사용한다.